ÉTIENNE LACOCHE

Cybersecurity Researcher · etienne.lacoche@pm.me

PENETRATION TEST REPORT

FlatSat electr0sm0g Lab Version — 56-finding vulnerable-by-design CubeSat

REPORT DATE	2026-11-02
CLASSIFICATION	PUBLIC — intentionally vulnerable laboratory
SECTOR	Space / aerospace (CubeSat, open hardware)
REGION	Worldwide (open-source lab)
RESEARCHER	Étienne Lacoche — Cybersecurity Researcher
REPORT ID	PT-ELECTR0SM0G-20261102

This report documents a laboratory system built to be broken. Every finding below is implemented by design, proven by an executable PoC on two targets (bit-for-bit Python simulator and real FlatSat 1 hardware), and mapped to SPARTA v3.2 (Space Attack Research and Tactic Analysis, The Aerospace Corporation). Nothing here describes a vulnerability in an operational system; the radio interface must never be pointed at a network that is not owned by the operator.

TABLE OF CONTENTS

01 Executive Summary

02 Findings Overview — 9 attack surfaces

03 Attack Surface Radar

04 Critical Severity Findings (4)

05 High Severity Findings (32)

06 Medium Severity Findings (17)

07 Low Severity Findings (3)

08 Scope & Infrastructure

09 Technology Stack

10 Security Posture

11 Remediation Roadmap

12 Methodology & Verification

13 Appendix — Finding Cross-Reference

01
Executive Summary

56	4	32	17	3
findings	critical	high	medium	low

FlatSat electr0sm0g Lab Version is a complete offensive-security extension of the official FlatSat v1.0 CubeSat firmware (Pwnsat/FlatSat, GPL-2.0-or-later), built and tested on FlatSat 1 hardware (Electronic Cats × PwnSat, RP2040 + 2× SX1262 LoRa). The assessment covers the full control path — RF uplink/downlink, SpaceCAN bus, flash-resident state, sensors, ground segment, and the OTA path — and documents **56 findings**, every one of them implemented in the real firmware, mirrored bit-for-bit in a Python simulator, and proven by an executable PoC that runs unchanged on both targets (56/56 POC OK, 112 captured transcripts).

Overall risk rating: **CRITICAL** — the vehicle is fully controllable by an unauthenticated uplink (complete initial-access chain, V-36), its code is upgradable without signature (V-18 → V-20 persistence), and it can be permanently crashed with a single malformed frame (V0-03).

Key findings

- **V-14 — MEMCPY TC → write-what-where → VTOR redirect → RP2040 RCE**: A `MEMCPY src(u32) dst(u32) len(u16)` telecommand takes *all three* arguments from the frame, bounded only by the address map.
- **V0-03 — BROADCAST_MSG length underflow → worker crash (silent death)**: `BROADCAST_MSG` computes the message length as `payload_total - 2` in unsigned arithmetic.
- **V-36 — GPS spoof → range-lock dissolve → XOR auth → privileged control (full chain)**: The GS (ground-station) gate — the craft's only "commands require a real station" control — arms only when the vehicle computes itself within 35 km of the station, and that position comes from a source with no checksum and no sour...

Priority: the three control-plane failures (unauthenticated privileged commanding, unsigned persistence, crash-on-frame) compound into total loss of the vehicle. Remediation roadmap in section 11; per-group countermeasures in the blue-team companion (docs/DEFENSE.md in the repository).

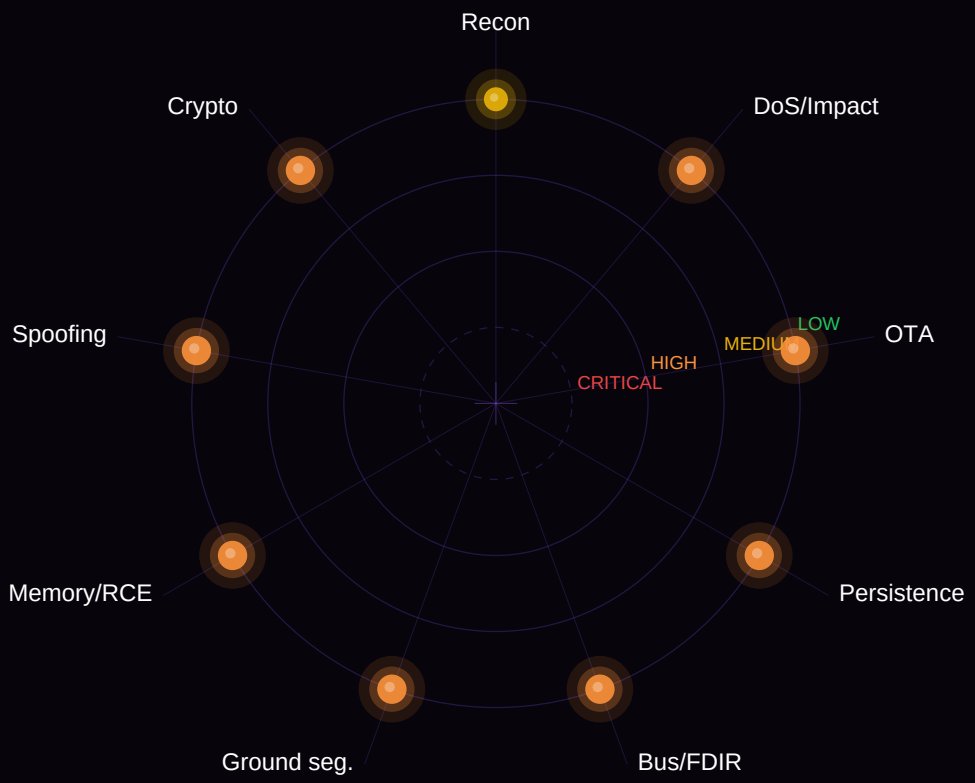
02
Findings Overview — 9 attack surfaces

Surface	Findings	Critical	High	Medium	Low	Flagship
1. Recon & leakage	9	0	0	6	3	V0-09 — FLASH_READ guarded only by a hardcoded magic tag
2. Crypto & link integrity	10	2	6	2	0	V0-02 — Hardcoded AES-128 ECB link key `PWNsatLabKey1234` in
3. Spoofing & command tampering	5	0	4	1	0	V0-05 — GPS NMEA accepted without checksum → position spoofi
4. Memory corruption & RCE	7	1	5	1	0	V-14 — MEMCPY TC → write-what-where → VTOR redirect → RP204
5. Ground segment & downlink	4	0	2	2	0	V-30 — Covert channel inside TM padding drains a FIFO over
6. Bus, sensors & FDIR	5	0	3	2	0	V-27 — FDIR consumes forged MIDs → attacker-launders contro
7. Persistence	4	0	3	1	0	V-38 — Anti-rollback counter writable by TC → patch level u
8. OTA & protection downgrade	4	1	2	1	0	V-18 — Unsigned OTA image push + slot activation (CRC-16 on
9. DoS & impact	8	0	7	1	0	V0-15 — No watchdog: hang/crash survives indefinitely until

Grouping mirrors the README catalog (9 attack-surface groups). Severity is taken from the repository's own writeups; the SPARTA v3.2 notional-risk triple is quoted per finding in the detailed sections.

03
Attack Surface Radar

Findings are distributed across the nine attack surfaces below. Radius encodes the severity mass of each surface; color encodes its dominant severity. Memory/RCE and Spoofing carry the highest-mass points; Recon is the broadest (every group is reachable from an unauthenticated uplink).



One point per attack surface; radius ∝ severity mass of its findings, color = dominant severity.

Read with the threat model (docs/THREAT-MODEL.md): three adversaries (passive eavesdropper, unauthenticated uplink, RF/PNT adversary) and five trust boundaries (B1–B5), each with exactly one weak or absent integrity mechanism.

04
Critical Severity Findings (4)

#1 [CRITICAL] Hardcoded AES-128 ECB link key `PWNsatLabKey1234` in image

Group: 2 · Crypto & link integrity ■ PoC: v002_hardcoded_ecb_key.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.95**	CRITICAL
RELEVANCE	**1.00**	APPLIABLE
PRIORITY	**0.95**	CRITICAL

The baseline secure link encrypts both directions with AES-128-ECB under the static key `"PWNsatLabKey1234"`.

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.03 · Gather Spacecraft Design Information: Cryptographic Algorithms · Notional risk: —

Secondary: PER-0004 Replace Cryptographic Keys

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Inject a per-craft key at launch (not in the image) and rotate via an authenticated

DETECTION EVIDENCE

• evidence/v002_hardcoded_ecb_key.txt (simulator) • evidence-hw/v002_hardcoded_ecb_key.txt (hardware, image H md5 bfc145c9…)

#2 [CRITICAL] OTAR with 128 NULL master keys: attacker installs his own SA key

Group: 2 · Crypto & link integrity ■ PoC: v110_otar_null_key.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.95**	CRITICAL
RELEVANCE	**1.00**	APPLIABLE
PRIORITY	**0.95**	CRITICAL

OTAR (Over-The-Air Rekeying) exists to provision SA keys remotely — but at power-up the 128-slot master-key table is all zeros and the only validation is `m < 128`.

TECHNICAL DETAILS

SPARTA v3.2: PER-0004 · Replace Cryptographic Keys · Notional risk: —

Secondary: IA-0008.01 Rogue Ground Station; EX-0003

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Refuse to OTAR under an unprovisioned master key: a `loaded` flag per slot, set by

DETECTION EVIDENCE

• evidence/v110_otar_null_key.txt (simulator) • evidence-hw/v110_otar_null_key.txt (hardware, image H md5 bfc145c9…)

#3 [CRITICAL] MEMCPY TC → write-what-where → VTOR redirect → RP2040 RCE

Group: 4 · Memory corruption & RCE ■ PoC: v114_memcpy_rce.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.95**	CRITICAL
RELEVANCE	**1.00**	APPLIABLE
PRIORITY	**0.95**	CRITICAL

A `MEMCPY src(u32) dst(u32) len(u16)` telecommand takes *all three* arguments from the frame, bounded only by the address map.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: EX-0012.03 Memory Write/Loads; EX-0010 Malicious Code (implant-ready)

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Deny-list the write targets of the memcpy TC (or allow-list: only SRAM payload

DETECTION EVIDENCE

• evidence/v114_memcpy_rce.txt (simulator) • evidence-hw/v114_memcpy_rce.txt (hardware, image H md5 bfc145c9…)

#4 [CRITICAL] Unsigned OTA image push + slot activation (CRC-16 only)

Group: 8 · OTA & protection downgrade ■ PoC: v118_ota_unsigned.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.95**	CRITICAL
RELEVANCE	**1.00**	APPLIABLE
PRIORITY	**0.95**	CRITICAL

The 4 MB QSPI NOR holds two 1.5 MB firmware slots plus a metadata sector, reachable over the radio through new APIDs.

TECHNICAL DETAILS

SPARTA v3.2: EX-0010 · Malicious Code (installed via unverified on-orbit update) · Notional risk: —
Secondary: IA-0007.02 Malicious Commanding via Valid GS (update path); CM0010 Update Software

IMPACT CONTEXT

Surface: OTA & protection downgrade ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 8: Verify a signature over the whole image before activation. Ed25519 in software costs

DETECTION EVIDENCE

• evidence/v118_ota_unsigned.txt (simulator) • evidence-hw/v118_ota_unsigned.txt (hardware, image H md5 bfc145c9…)

05
High Severity Findings (32)

#5 [HIGH] BROADCAST_MSG length underflow → worker crash (silent death)

Group: 4 · Memory corruption & RCE ■ PoC: v003_broadcast_underflow_crash.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`BROADCAST_MSG` computes the message length as `payload_total - 2` in unsigned arithmetic.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: IMP-0003 · Denial (v4.0: IMP-0013 Resource Exhaustion or Contention)

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Validate `payload_total >= 2` (and an upper bound) before the subtraction — a

DETECTION EVIDENCE

• evidence/v003_broadcast_underflow_crash.txt (simulator) • evidence-hw/v003_broadcast_underflow_crash.txt (hardware, image H md5 bfc145c9…)

#6 [HIGH] SET_THRUSTER accepted from raw radio, no authentication

Group: 3 · Spoofing & command tampering ■ PoC: v004_set_thruster_noauth.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`SET_THRUSTER` (APID 0x04) executes straight from the raw radio with no GS session, no range gate, no credential — even though the firmware has a ground-station gating family (APIDs 0x11–0x13) for other command flows.

TECHNICAL DETAILS

SPARTA v3.2: EX-0005.02 · Exploit Hardware/Firmware Corruption: Malicious Use of Hardware Commands · Notional risk: —
Secondary: EX-0012.07 Propulsion Subsystem; IMP-0007 Native Functionality Abuse (v4.0)

IMPACT CONTEXT

Surface: Spoofing & command tampering ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 3: Put propulsion-class TCs behind the GS session gate (CM0031 Authentication — session

DETECTION EVIDENCE

• evidence/v004_set_thruster_noauth.txt (simulator) • evidence-hw/v004_set_thruster_noauth.txt (hardware, image H md5 bfc145c9…)

#7 [HIGH] GPS NMEA accepted without checksum → position spoofing

Group: 3 · Spoofing & command tampering ■ PoC: v005_gps_no_checksum.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The GPS chain trusts whatever position the receiver reports: no NMEA checksum verification, no position-jump plausibility.

TECHNICAL DETAILS

SPARTA v3.2: EX-0014.04 · Spoofing: Position, Navigation, and Timing (PNT) Spoofing · Notional risk: — Secondary: EX-0014.03 Sensor Data

IMPACT CONTEXT

Surface: Spoofing & command tampering ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 3: Verify the NMEA `*CK` XOR checksum in `sensors.cpp` before accepting a sentence

DETECTION EVIDENCE

• evidence/v005_gps_no_checksum.txt (simulator) • evidence-hw/v005_gps_no_checksum.txt (hardware, image H md5 bfc145c9…)

#8 [HIGH] GS authentication = challenge XOR static key (offline-computable)

Group: 2 · Crypto & link integrity ■ PoC: v006_gs_auth_xor_static.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Ground-station mode gating (the baseline's only "authentication") asks the claimant for `response = challenge ^ 0xC0DEFACE`.

TECHNICAL DETAILS

SPARTA v3.2: EX-0003 · Modify Authentication Process (weak scheme) · Notional risk: — Secondary: IA-0008.01 Rogue Ground Station; DE-0004 Masquerading

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Replace the XOR scheme with a real keyed MAC over fresh nonce (AES-CMAC is already

DETECTION EVIDENCE

• evidence/v006_gs_auth_xor_static.txt (simulator) • evidence-hw/v006_gs_auth_xor_static.txt (hardware, image H md5 bfc145c9…)

#9 [HIGH] No anti-replay protection on telecommands

Group: 2 · Crypto & link integrity ■ PoC: v007_no_replay_protection.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The received SPP sequence number is logged and never compared.

TECHNICAL DETAILS

SPARTA v3.2: EX-0001.01 · Replay: Command Packets · Notional risk: 25|24|21
Secondary: EXF-0001 Replay (observational)

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Enforce a monotonically-increasing sequence window per link state (SDLS-style ARC

DETECTION EVIDENCE

• evidence/v007_no_replay_protection.txt (simulator) • evidence-hw/v007_no_replay_protection.txt (hardware, image H md5 bfc145c9…)

#10 [HIGH] Crypto-bypass: AES engine can be switched OFF over the air

Group: 2 · Crypto & link integrity ■ PoC: v010_cleartext_downgrade.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`AES_CONFIG` toggles the whole secure link — and the toggle command itself is parsed in **cleartext** even while the link is encrypted, because the code only attempts decryption when the payload length is a multiple of 16.

TECHNICAL DETAILS

SPARTA v3.2: EX-0006 · Disable/Bypass Encryption · Notional risk: 24|21|17
Secondary: DE-0003.07 On-Board Values Obfuscation: Cryptographic Modes (18|15|11)

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Accept the toggle only inside an authenticated context (GS session or wrapped +

DETECTION EVIDENCE

• evidence/v010_cleartext_downgrade.txt (simulator) • evidence-hw/v010_cleartext_downgrade.txt (hardware, image H md5 bfc145c9…)

#11 [HIGH] AES-ECB malleability: TC bit-flip without any integrity check

Group: 2 · Crypto & link integrity ■ PoC: v011_ecb_bitflip.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Two ECB structural flaws compound: the SPP primary header (type, APID, flags, seq, length) always travels in the clear, so routing metadata is visible and editable to anyone with an SDR; and the ECB payload is malleable — flipping...

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: EX-0012.02 Internal Routing Tables (APID re-routing); EX-0006

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Add a per-frame MAC over header+payload (AES-CMAC already exists in the v2 core);

DETECTION EVIDENCE

• evidence/v011_ecb_bitflip.txt (simulator) • evidence-hw/v011_ecb_bitflip.txt (hardware, image H md5 bfc145c9…)

#12 [HIGH] SpaceCAN bridge: junk storm drives nodes BUS-OFF (bus jam)

Group: 9 · DoS & impact ■ PoC: v013_spacecan_busoff.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The radio↔SpaceCAN bridge injects any frame the uplink carries, with no source authentication.

TECHNICAL DETAILS

SPARTA v3.2: LM-0002 · Exploit Lack of Bus Segregation · Notional risk: 24|21|17
Secondary: EX-0013.02 Flooding: Erroneous Input (25|24|21)

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Authenticate bridge-injected frames (a 4-byte token/MAC per frame — SpaceCAN's own

DETECTION EVIDENCE

• evidence/v013_spacecan_busoff.txt (simulator) • evidence-hw/v013_spacecan_busoff.txt (hardware, image H md5 bfc145c9…)

#13 [HIGH] Beacon-flood (SET_BEACON_RATE) freezes the mission loop

Group: 9 · DoS & impact ■ PoC: v014_beacon_flood.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`SET_BEACON_RATE` takes its interval in seconds and happily accepts `0`.

TECHNICAL DETAILS

SPARTA v3.2: EX-0013 · Flooding · Notional risk: 25|24|21
Secondary: DE-0002 Disrupt or Deceive Downlink; IMP Denial

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Validate the interval against a sane minimum (e.g. `1 <= v <= 30`, and reject

DETECTION EVIDENCE

• evidence/v014_beacon_flood.txt (simulator) • evidence-hw/v014_beacon_flood.txt (hardware, image H md5 bfc145c9…)

#14 [HIGH] No watchdog: hang/crash survives indefinitely until power cycle

Group: 9 · DoS & impact ■ PoC: v015_no_watchdog.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The baseline never arms the RP2040's hardware watchdog, so there is no path back from a crash or hang: the craft that dies from the V0-03 one-byte broadcast stays silent forever.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: DE-0003.11 Watchdog Timer (WDT) for Evasion (missing WDT = abuse surface)

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Arm the RP2040 hardware watchdog with a timeout above the worst legitimate loop

DETECTION EVIDENCE

• evidence/v015_no_watchdog.txt (simulator) • evidence-hw/v015_no_watchdog.txt (hardware, image H md5 bfc145c9…)

#15 [HIGH] Heartbleed-style RAM leak inside TM 'padding' (GS challenge disclosed)

Group: 4 · Memory corruption & RCE ■ PoC: v104_leak_padding.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Short telemetry frames are padded to 64 bytes, but in mode 1 the pad is filled from a live RAM string pool instead of zeros — the exact Heartbleed/ESTCube-1 ICP pattern the course teaches.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: EXF-0003.02 Downlink Exfiltration

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Zero the TX slack: `memset` pad region before fill (the upstream `spp_unpack` already

DETECTION EVIDENCE

• evidence/v104_leak_padding.txt (simulator) • evidence-hw/v104_leak_padding.txt (hardware, image H md5 bfc145c9…)

#16 [HIGH] Arbitrary MEM_READ: SA table + GS challenge walk out over raw radio

Group: 4 · Memory corruption & RCE ■ PoC: v105_mem_read.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`MEM_READ` is a laboratory oscilloscope probe left wired to the radio: `offset(u32) len(u16)`, checked only against the *address map* (RP2040 SRAM 0x20000000–0x20041000, XIP, a few peripherals) — never against what the data is.

TECHNICAL DETAILS

SPARTA v3.2: EX-0012.03 · Modify On-Board Values: Memory Write/Loads · Notional risk: 19|14|9 (EX-0012)
Secondary: EXF-0003.02; REC-0001.03

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Replace raw address/length with an allow-listed *symbol table* API (read these 6

DETECTION EVIDENCE

• evidence/v105_mem_read.txt (simulator) • evidence-hw/v105_mem_read.txt (hardware, image H md5 bfc145c9…)

#17 [HIGH] 43 of 64 SDLS security associations default to Clear (auth-free)

Group: 2 · Crypto & link integrity ■ PoC: v108_sdls_clear_sas.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The lab's simulated SDLS mirrors the CryptoLib posture the course dissects: a 64-entry security-association table in which only SAs 0–20 were ever configured; the other 43 — including SPI **44**, the default applied to every frame...

TECHNICAL DETAILS

SPARTA v3.2: EX-0006 · Disable/Bypass Encryption · Notional risk: 24|21|17
Secondary: DE-0003.07 Cryptographic Modes (18|15|11)

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Default-deny SA policy: `ast == 0` must mean *reject*, not *clear* — Clear mode

DETECTION EVIDENCE

• evidence/v108_sdls_clear_sas.txt (simulator) • evidence-hw/v108_sdls_clear_sas.txt (hardware, image H md5 bfc145c9…)

#18 [HIGH] Unbounded SPI: OOB table read passes; SPI 9000 hangs the worker

Group: 4 · Memory corruption & RCE ■ PoC: v109_spi_oob.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The security-association lookup takes the 16-bit SPI straight from the attacker's frame and uses it as an array index without the `spi < 64` bound.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: EX-0013.02 Erroneous Input; V0-15 chain (no WDT)

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: The bound check (`if (spi >= SDLS_NUM_SA) reject`) is free: one compare per frame.

DETECTION EVIDENCE

• evidence/v109_spi_oob.txt (simulator) • evidence-hw/v109_spi_oob.txt (hardware, image H md5 bfc145c9…)

#19 [HIGH] KEY_VERIFY key-confirmation oracle + CTR keystream recoverable from clear header

Group: 2 · Crypto & link integrity ■ PoC: v111_key_verify_oracle.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		**HIGH**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.75**		**HIGH**

`KEY_VERIFY` was meant to help operators confirm which SA key is live.

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.03 · Gather Spacecraft Design Information: Cryptographic Algorithms · Notional risk: —

Secondary: EX-0006 Disable/Bypass Encryption

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Require GS-session/SDLS authentication for `KEY_VERIFY`, or return a truncated MAC

DETECTION EVIDENCE

• evidence/v111_key_verify_oracle.txt (simulator) • evidence-hw/v111_key_verify_oracle.txt (hardware, image H md5 bfc145c9…)

#20 [HIGH] Silent TC tampering: clear-header APID re-routing + ECB block splice

Group: 3 · Spoofing & command tampering ■ PoC: v112_tc_bitflip.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		**HIGH**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.75**		**HIGH**

The uplink runs with the radio's CRC disabled (`setCRC(0)` in `ruplink.cpp`) and the data field is AES-**ECB** with no per-frame integrity tag on the Clear path.

TECHNICAL DETAILS

SPARTA v3.2: EX-0012.02 · Modify On-Board Values: Internal Routing Tables · Notional risk: 19|14|9 (EX-0012)

Secondary: EX-0009.01; EX-0006

IMPACT CONTEXT

Surface: Spoofing & command tampering ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 3: Turn the radio CRC on (`DEF_RADIO_CRC` / `setCRC(1)`): catches accidental corruption

DETECTION EVIDENCE

• evidence/v112_tc_bitflip.txt (simulator) • evidence-hw/v112_tc_bitflip.txt (hardware, image H md5 bfc145c9…)

#21 [HIGH] SET_LOG_NAME unbounded copy overwrites protection-state guard variables

Group: 4 · Memory corruption & RCE ■ PoC: v113_log_name_overflow.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The log-name setter copies the TC string into `char s_log_name[32]` with an unbounded byte loop (`memservSetLogName`, `firmware/memserv.cpp:103-115`) semantics and no length bound, and the link layout parks the mission's protectio...

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: DE-0003.07 Cryptographic Modes

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Bound the copy (bounded `strncpy` into `sizeof(s_log_name)-1`) and validate the charset —

DETECTION EVIDENCE

• evidence/v113_log_name_overflow.txt (simulator) • evidence-hw/v113_log_name_overflow.txt (hardware, image H md5 bfc145c9…)

#22 [HIGH] Uplink flood (blocking ledBlink + error TMs) starves telemetry

Group: 9 · DoS & impact ■ PoC: v115_uplink_starvation.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The command handler reacts to *every* rejected telecommand by blocking on a multi-second LED animation **and** emitting an AES-wrapped error TM.

TECHNICAL DETAILS

SPARTA v3.2: EX-0013.02 · Flooding: Erroneous Input · Notional risk: 25|24|21
Secondary: IMP Denial (v4.0: IMP-0013 Resource Exhaustion or Contention)

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Move the LED feedback out of the TC path: on RP2040 a PIO state machine drives WS2812

DETECTION EVIDENCE

• evidence/v115_uplink_starvation.txt (simulator) • evidence-hw/v115_uplink_starvation.txt (hardware, image H md5 bfc145c9…)

#23 [HIGH] TEST APID window (0xF0–0xFF) opens in safe mode, no own auth

Group: 8 · OTA & protection downgrade ■ PoC: v116_priv_confusion.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The v2 firmware adds a TEST APID window (0xF0–0xFF) — the embedded stand-in for OPS-SAT's "root-CAN" — and gates it with exactly one condition: *is the craft in safe mode?*.

TECHNICAL DETAILS

SPARTA v3.2: EX-0011 · Exploit Reduced Protections During Safe-Mode · Notional risk: 24|21|17
Secondary: IA-0010 Unauthorized Access During Safe-Mode; REC-0007 (15|11|5)

IMPACT CONTEXT

Surface: OTA & protection downgrade ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 8: Bind the TEST window to *provenance*, not state: require an authenticated GS session

DETECTION EVIDENCE

• evidence/v116_priv_confusion.txt (simulator) • evidence-hw/v116_priv_confusion.txt (hardware, image H md5 bfc145c9…)

#24 [HIGH] Forged software-bus MIDs (cFS SB analogue) consumed as truth

Group: 6 · Bus, sensors & FDIR ■ PoC: v117_sb_forged_mids.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

v2 adds a miniature cFS software bus (`sb.cpp`): modules exchange data by **Message ID only**, with no sender identity attached.

TECHNICAL DETAILS

SPARTA v3.2: EX-0014.02 · Spoofing: Bus Traffic Spoofing · Notional risk: —
Secondary: LM-0002 Exploit Lack of Bus Segregation (24|21|17); EX-0012.10 Command & Data Handling Subsystem

IMPACT CONTEXT

Surface: Bus, sensors & FDIR ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 6: Enable `SB_AUTH` (4-byte per-MID tag) as the default; cost: a few bytes per internal

DETECTION EVIDENCE

• evidence/v117_sb_forged_mids.txt (simulator) • evidence-hw/v117_sb_forged_mids.txt (hardware, image H md5 bfc145c9…)

#25 [HIGH] Flash-resident scheduled task queue replays after any reboot

Group: 7 · Persistence ■ PoC: v119_sched_persistence.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

The v2 firmware ships a scheduled-telecommand facility: `SCHED_ADD` stores `{every, apid, payload}` entries in the flash config sector, and the boot path replays them **without checking where they came from**.

TECHNICAL DETAILS

SPARTA v3.2: PER-0002.02 · Software Backdoor · Notional risk: 24|21|17
Secondary: EX-0012.05 Scheduling Algorithm

IMPACT CONTEXT

Surface: Persistence ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 7: Sign or MAC the schedule sector with an update-time key and validate at replay; drop

DETECTION EVIDENCE

• evidence/v119_sched_persistence.txt (simulator) • evidence-hw/v119_sched_persistence.txt (hardware, image H md5 bfc145c9…)

#26 [HIGH] FDIR contingency dictionary = flash-resident executable trojan

Group: 7 · Persistence ■ PoC: v120_fdict_contingency.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

On entering safe mode the FDIR executes a short list of "contingency" telecommands kept in flash — the embedded twin of the course's Java supervisor `executable.jar`: started early, almost always active, and the first thing a tire...

TECHNICAL DETAILS

SPARTA v3.2: PER-0002.02 · Software Backdoor · Notional risk: 24|21|17
Secondary: EX-0011 (runs on safe entry); REC-0001.09 Fault Management

IMPACT CONTEXT

Surface: Persistence ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 7: Burn the dictionary hash (`FDIR_HASH_SET`, sub 7) at integration, not after an incident,

DETECTION EVIDENCE

• evidence/v120_fdict_contingency.txt (simulator) • evidence-hw/v120_fdict_contingency.txt (hardware, image H md5 bfc145c9…)

#27 [HIGH] Forced safe mode = protection downgrade (crypto off, ARC 5→15, persists)

Group: 8 · OTA & protection downgrade ■ PoC: v122_forced_safe_downgrade.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		HIGH
RELEVANCE	**1.00**		APPLIABLE
PRIORITY	**0.75**		HIGH

Safe mode is not only a degraded *attitude* state — it applies a whole relaxation table, and each entry is one of the course's six EX-0006 vectors: maintenance/test APIDs accepted (V-16), null-cipher fallback (`AES_CONFIG` off, V0...

TECHNICAL DETAILS

SPARTA v3.2: DE-0005 · Subvert Protections via Safe-Mode · Notional risk: —
Secondary: EX-0011 (24|21|17); DE-0003.07 (18|15|11)

IMPACT CONTEXT

Surface: OTA & protection downgrade ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 8: Make the relaxation table symmetric: every protection switched off by `safeEnter()` must

DETECTION EVIDENCE

• evidence/v122_forced_safe_downgrade.txt (simulator) • evidence-hw/v122_forced_safe_downgrade.txt (hardware, image H md5 bfc145c9…)

#28 [HIGH] Full unauthenticated SpaceCAN bus over the radio bridge (jam/spoof/overflow)

Group: 6 · Bus, sensors & FDIR ■ PoC: v125_spacecan_full_bus.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		HIGH
RELEVANCE	**1.00**		APPLIABLE
PRIORITY	**0.75**		HIGH

The radio-to-SpaceCAN bridge (V-16's `SC_INJECT`) does not merely *forward* commands: it exposes every CAN-layer attack class that the course lists for shared buses, because the injected frames carry no origin, no authentication, ...

TECHNICAL DETAILS

SPARTA v3.2: LM-0002 · Exploit Lack of Bus Segregation · Notional risk: 24|21|17
Secondary: EX-0013.01 Valid Commands; EX-0014.02 Bus Traffic Spoofing

IMPACT CONTEXT

Surface: Bus, sensors & FDIR ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 6: Authenticate bridge frames: SpaceCAN already carries an 8-bit *message index* field —

DETECTION EVIDENCE

• evidence/v125_spacecan_full_bus.txt (simulator) • evidence-hw/v125_spacecan_full_bus.txt (hardware, image H md5 bfc145c9…)

#29 [HIGH] FDIR consumes forged MIDs → attacker-launders control of the safety loop

Group: 6 · Bus, sensors & FDIR ■ PoC: v127_fdir_consumes_forged_mids.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		**HIGH**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.75**		**HIGH**

The safety loop reads the same software-bus values as everything else (V-17), so the FDIR cannot tell a forged attitude rate from gyro data: there is no source authentication on the bus that feeds it.

TECHNICAL DETAILS

SPARTA v3.2: EX-0014.03 · Spoofing: Sensor Data · Notional risk: —
Secondary: DE-0001 Disable Fault Management (24|21|17); EX-0012.08 ADCS

IMPACT CONTEXT

Surface: Bus, sensors & FDIR ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 6: Authenticate the bus (V-17's `SB_AUTH`) and, more specifically, make FDIR inputs

DETECTION EVIDENCE

• evidence/v127_fdir_consumes_forged_mids.txt (simulator) • evidence-hw/v127_fdir_consumes_forged_mids.txt (hardware, image H md5 bfc145c9…)

#30 [HIGH] GS challenge has no TRNG (millis ^ GPS) → predicted-challenge session hijack

Group: 5 · Ground segment & downlink ■ PoC: v128_gs_session_hijack.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		**HIGH**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.75**		**HIGH**

GS authentication is a two-phase challenge/response: the craft publishes a 32-bit challenge, the requester answers `challenge XOR key`.

TECHNICAL DETAILS

SPARTA v3.2: EX-0003 · Modify Authentication Process · Notional risk: —
Secondary: IA-0008.01 Rogue Ground Station; DE-0004 Masquerading

IMPACT CONTEXT

Surface: Ground segment & downlink ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 5: Add real entropy: a ROSC-based collector on RP2040 is ~50 lines plus a startup health

DETECTION EVIDENCE

• evidence/v128_gs_session_hijack.txt (simulator) • evidence-hw/v128_gs_session_hijack.txt (hardware, image H md5 bfc145c9…)

#31 [HIGH] Covert channel inside TM padding drains a FIFO over the legitimate downlink

Group: 5 · Ground segment & downlink ■ PoC: v130_stego_padding_channel.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Telemetry frames are fixed-length, and their padding is not required to be inert: `PADDING_CONFIG mode=2` fills the beacon's 43 padding bytes (`payload[21:64]` of the 64-byte beacon) by draining a 1 KiB "covert queue" fed by the u...

TECHNICAL DETAILS

SPARTA v3.2: EXF-0004 · Out-of-Band Communications Link (covert variant) · Notional risk: —
Secondary: EXF-0003.02 Downlink Exfiltration (22|19|14 EXF-0001 class)

IMPACT CONTEXT

Surface: Ground segment & downlink ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 5: Gate `PADDING_CONFIG mode=2` and `COVERT_ENQ` behind GS mode; refuse mode

DETECTION EVIDENCE

• evidence/v130_stego_padding_channel.txt (simulator) • evidence-hw/v130_stego_padding_channel.txt (hardware, image H md5 bfc145c9…)

#32 [HIGH] ADCS momentum spam (30 valid thruster TCs) → TUMBLE safe + detumble saturation

Group: 9 · DoS & impact ■ PoC: v133_adcstumble_saturation.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Every `SET_THRUSTER` telecommand is accepted from the raw radio and injects an unmitigated impulse into the integrated attitude state — the "10 Hz spam" pattern from the course.

TECHNICAL DETAILS

SPARTA v3.2: EX-0012.08 · Modify On-Board Values: Attitude Determination & Control Subsystem · Notional risk: 19|14|9 (EX-0012)
Secondary: EX-0013.01 Valid Commands (25|24|21); IMP Degradation

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Require GS-mode authentication for `SET_THRUSTER` (removes the raw-radio

DETECTION EVIDENCE

• evidence/v133_adcstumble_saturation.txt (simulator) • evidence-hw/v133_adcstumble_saturation.txt (hardware, image H md5 bfc145c9…)

#33 [HIGH] Heater/eclipse power drain → brownout reset wipes ARC, cookie, crypto state

Group: 9 · DoS & impact ■ PoC: v134_brownout_drain.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

Four virtual heaters (`HEATER`, one 2-byte TC each) draw 2.4 W apiece against a 40 Wh battery that solar (3 W peak, 0 W in eclipse) cannot cover.

TECHNICAL DETAILS

SPARTA v3.2: EX-0012.09 · Modify On-Board Values: Electrical Power Subsystem · Notional risk: 19|14|9 (EX-0012)

Secondary: IMP Degradation/Denial; state-reset chain into V-07/V-21

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Require authentication on `HEATER` (and on `FDIR_CONFIG` sub 10, which is

DETECTION EVIDENCE

• evidence/v134_brownout_drain.txt (simulator) • evidence-hw/v134_brownout_drain.txt (hardware, image H md5 bfc145c9…)

#34 [HIGH] Beacon/broadcast downlink saturation (service_control analogue)

Group: 9 · DoS & impact ■ PoC: v135_beacon_broadcast_saturation.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**	**HIGH**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.75**	**HIGH**

`SET_BEACON_RATE(0)` — intended as a nominal cadence control — makes the craft emit a 64-byte beacon on **every 100 ms mission tick**, and because the beacon only starts ticking once the rate command *changed* it (the baseline qui...

TECHNICAL DETAILS

SPARTA v3.2: EX-0013.01 · Flooding: Valid Commands · Notional risk: 25|24|21

Secondary: DE-0002 Disrupt or Deceive Downlink; IMP Denial

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Clamp `SET_BEACON_RATE` to a minimum interval (reject 0 or reinterpret it

DETECTION EVIDENCE

• evidence/v135_beacon_broadcast_saturation.txt (simulator) • evidence-hw/v135_beacon_broadcast_saturation.txt (hardware, image H md5 bfc145c9…)

#35 [HIGH] GPS spoof → range-lock dissolve → XOR auth → privileged control (full chain)

Group: 3 · Spoofing & command tampering ■ PoC: v136_gps_spoof_chain.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.75**		**HIGH**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.75**		**HIGH**

The GS (ground-station) gate — the craft's only "commands require a real station" control — arms only when the vehicle computes itself within 35 km of the station, and that position comes from a source with no checksum and no sour...

TECHNICAL DETAILS

SPARTA v3.2: EX-0014.04 · Spoofing: Position, Navigation, and Timing (PNT) Spoofing · Notional risk: — Secondary: IA-0008.01; EX-0003; EX-0014.03

IMPACT CONTEXT

Surface: Spoofing & command tampering ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 3: Tighten the plausibility threshold to a physically sane bound and

DETECTION EVIDENCE

• evidence/v136_gps_spoof_chain.txt (simulator) • evidence-hw/v136_gps_spoof_chain.txt (hardware, image H md5 bfc145c9…)

#36 [HIGH] Anti-rollback counter writable by TC → patch level unenforceable

Group: 7 · Persistence ■ PoC: v138_arwc_rollback.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	0.75	HIGH
RELEVANCE	1.00	APPLIABLE
PRIORITY	0.75	HIGH

The dual-slot OTA machinery ships an anti-rollback counter (ARWC) intended to stop the vehicle from re-running older, vulnerable firmware — the SPR-215 property inverted (here the *protection itself* is the flawed design).

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.03 · Exploit Code Flaws: Known Vulnerability (COTS/FOSS) · Notional risk: 24|21|17
Secondary: CM0010 Update Software (countermeasure defeated); IMP-0007 Native Functionality Abuse (v4.0)

IMPACT CONTEXT

Surface: Persistence ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 7: Make the counter **monotonic**: when `enforce=1`, reject writes of

DETECTION EVIDENCE

• evidence/v138_arwc_rollback.txt (simulator) • evidence-hw/v138_arwc_rollback.txt (hardware, image H md5 bfc145c9…)

06

Medium Severity Findings (17)

#37 [MEDIUM] Unauthenticated SEND_FW + APID surface enumeration (CPE fingerprint)

Group: 1 · Recon & leakage ■ PoC: v001_send_fw_cpe.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

An attacker with a cheap 918 MHz transceiver sweeps every telecommand APID on the raw uplink.

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.01 · Gather Spacecraft Design Information: Software Design · Notional risk: 6|4|2 (REC-0002)
Secondary: REC-0002.01 Identifiers; REC-0001.02 Firmware

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Default-deny APID policy at the dispatcher: answer unknown/unauthorized APIDs with a

DETECTION EVIDENCE

• evidence/v001_send_fw_cpe.txt (simulator) • evidence-hw/v001_send_fw_cpe.txt (hardware, image H md5 bfc145c9…)

#38 [MEDIUM] RESETC unauthenticated → one-TC reboot DoS, window loss

Group: 9 · DoS & impact ■ PoC: v008_resetc_unauth_dos.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

`RESETC` reboots the craft with no authentication: one frame on the raw radio and the C&DH restarts.

TECHNICAL DETAILS

SPARTA v3.2: EX-0005.02 · Malicious Use of Hardware Commands · Notional risk: —
Secondary: DE-0002 Disrupt or Deceive Downlink (.01 Inhibit Ground System Functionality)

IMPACT CONTEXT

Surface: DoS & impact ■ Interface: uplink flood / resource saturation

REMEDIATION

docs/DEFENSE.md · group 9: Gate RESETC behind the GS session (CM0031 Authentication) or require a

DETECTION EVIDENCE

• evidence/v008_resetc_unauth_dos.txt (simulator) • evidence-hw/v008_resetc_unauth_dos.txt (hardware, image H md5 bfc145c9…)

#39 [MEDIUM] FLASH_READ guarded only by a hardcoded magic tag

Group: 1 · Recon & leakage ■ PoC: v009_flash_read_hardcoded_tag.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The flash "window" holding operational secrets is unlocked by a two-value magic pair — `window_id = 0xA5`, `unlock = 0xC35A` — compiled into the image.

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.02 · Gather Spacecraft Design Information: Firmware · Notional risk: —
Secondary: EXF-0003.02 Signal Interception: Downlink Exfiltration

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Gate FLASH_READ behind the GS session (CM0031 Authentication) rather than a magic

DETECTION EVIDENCE

• evidence/v009_flash_read_hardcoded_tag.txt (simulator) • evidence-hw/v009_flash_read_hardcoded_tag.txt (hardware, image H md5 bfc145c9…)

#40 [MEDIUM] USB debug mode bypasses link authentication

Group: 2 · Crypto & link integrity ■ PoC: v012_usb_debug_bypass.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

`DEBUG_CONFIG` (APID 0x10, USB-only) flips a global `bypass_secure_link`: the USB path skips the AES engine entirely and **every telemetry frame leaves in cleartext on every transport** — including the radio downlink.

TECHNICAL DETAILS

SPARTA v3.2: IA-0011 · Auxiliary Device Compromise · Notional risk: —
Secondary: CM0037 Disable Physical Ports (countermeasure gap)

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: SPARTA CM0037-style physical hygiene: disable or fuse the USB boot ROM/serial in the

DETECTION EVIDENCE

• evidence/v012_usb_debug_bypass.txt (simulator) • evidence-hw/v012_usb_debug_bypass.txt (hardware, image H md5 bfc145c9…)

#41 [MEDIUM] SPP unpack off-by-one: TM payload over-read (RAM byte leak)

Group: 4 · Memory corruption & RCE ■ PoC: v016_spp_offbyone.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The SPP unpacker copies `length + 1` bytes out of the receive buffer but never checks that the frame actually contains them.

TECHNICAL DETAILS

SPARTA v3.2: EX-0009.01 · Exploit Code Flaws: Flight Software · Notional risk: 24|21|17
Secondary: EXF-0003.02 Downlink Exfiltration

IMPACT CONTEXT

Surface: Memory corruption & RCE ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 4: Validate `received_bytes >= header.length + 7` before the copy and cap

DETECTION EVIDENCE

• evidence/v016_spp_offbyone.txt (simulator) • evidence-hw/v016_spp_offbyone.txt (hardware, image H md5 bfc145c9…)

#42 [MEDIUM] GPS parser `strtok` column handling → forged sentences accepted

Group: 3 · Spoofing & command tampering ■ PoC: v017_gps_strtok_columns.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The NMEA splitter uses `strtok_r`-style splitting, which *skips* runs of delimiters.

TECHNICAL DETAILS

SPARTA v3.2: EX-0014.03 · Spoofing: Sensor Data · Notional risk: —
Secondary: EX-0009.01 (parser defect)

IMPACT CONTEXT

Surface: Spoofing & command tampering ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 3: Split NMEA positionally (`strsep` keeping empty tokens, or ` sscanf` with `%[^,]`

DETECTION EVIDENCE

• evidence/v017_gps_strtok_columns.txt (simulator) • evidence-hw/v017_gps_strtok_columns.txt (hardware, image H md5 bfc145c9…)

#43 [MEDIUM] SEND_FW unauthenticated inventory/version leak (CPE match to CVE catalogue)

Group: 1 · Recon & leakage ■ PoC: v101_send_fw_inventory.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

One empty `SEND_FW` telecommand over the raw radio makes the spacecraft answer with its exact firmware version (`1.0.0`).

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.01 · Gather Spacecraft Design Information: Software Design · Notional risk: —
Secondary: REC-0002.01 Identifiers

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Gate version/identity queries behind SPARTA CM0031-style Authentication (challenge or

DETECTION EVIDENCE

• evidence/v101_send_fw_inventory.txt (simulator) • evidence-hw/v101_send_fw_inventory.txt (hardware, image H md5 bfc145c9…)

#44 [MEDIUM] Over-talkative beacon discloses mode, crypto state, battery, eclipse

Group: 1 · Recon & leakage ■ PoC: v102_chatty_beacon.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The beacon is designed for operators but speaks like a debug console.

TECHNICAL DETAILS

SPARTA v3.2: REC-0003 · Gather Spacecraft Communications Information · Notional risk: —
Secondary: REC-0007 Monitor for Safe-Mode Indicators (15|11|5); EXF-0003.02

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Enable the CM0006-style cloak (`DEF_CLOAK`) by default: zeroes the 13-byte status

DETECTION EVIDENCE

• evidence/v102_chatty_beacon.txt (simulator) • evidence-hw/v102_chatty_beacon.txt (hardware, image H md5 bfc145c9…)

#45 [MEDIUM] 16-bit volatile anti-replay counter, W=5 window, wraps at 65536

Group: 2 · Crypto & link integrity ■ PoC: v107_arc_replay.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The v2 firmware's SDLS anti-replay counter (ARC) is configured — exactly as the course asks the students to measure — at **16 bits with an acceptance window W=5**, and lives in plain SRAM.

TECHNICAL DETAILS

SPARTA v3.2: EX-0001.01 · Replay: Command Packets · Notional risk: 25|24|21
Secondary: DE-0003.11 WDT/counter-reset interaction

IMPACT CONTEXT

Surface: Crypto & link integrity ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 2: Persist `arc_last` monotonically (flash counter with wear leveling, or the boot-count

DETECTION EVIDENCE

• evidence/v107_arc_replay.txt (simulator) • evidence-hw/v107_arc_replay.txt (hardware, image H md5 bfc145c9…)

#46 [MEDIUM] Persistence cookie in RP2040 watchdog scratch registers (boot policy)

Group: 7 · Persistence ■ PoC: v121_watchdog_cookie.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The RP2040's watchdog block exposes eight scratch registers that are **retained across a watchdog/soft reboot** and lost only on power removal.

TECHNICAL DETAILS

SPARTA v3.2: PER-0001 · Memory Compromise · Notional risk: —
Secondary: DE-0003.11 Watchdog Timer (WDT) for Evasion; EX-0012.11 Watchdog Timer (WDT)

IMPACT CONTEXT

Surface: Persistence ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 7: Do not derive security policy from registers whose lifetime differs from the state they

DETECTION EVIDENCE

• evidence/v121_watchdog_cookie.txt (simulator) • evidence-hw/v121_watchdog_cookie.txt (hardware, image H md5 bfc145c9…)

#47 [MEDIUM] No TC journal by default; optional log capped at 128 entries

Group: 8 · OTA & protection downgrade ■ PoC: v123_tc_logging_absent.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

Every accepted telecommand is executed and forgotten.

TECHNICAL DETAILS

SPARTA v3.2: DE-0003.08 · On-Board Values Obfuscation: Received Commands · Notional risk: —
Secondary: Overflow Audit Log (DE family); attribution gap

IMPACT CONTEXT

Surface: OTA & protection downgrade ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 8: Ship the journal ON: it costs one flash sector and a CMAC-free append per TC; write

DETECTION EVIDENCE

• evidence/v123_tc_logging_absent.txt (simulator) • evidence-hw/v123_tc_logging_absent.txt (hardware, image H md5 bfc145c9…)

#48 [MEDIUM] On-board EWMA anomaly detector evadable by slow ramp

Group: 6 · Bus, sensors & FDIR ■ PoC: v124_ewma_ramp_evasion.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The v2 firmware ships the course's "impoverished LSTM": a hand-tuned EWMA/EWV detector on four channels (virtual tilt, TC rate, mean power, bus voltage) with one multiply per sample, ~10 µs, and an alarm rule `|x – µ| > z·σ`, z ∈ ...

TECHNICAL DETAILS

SPARTA v3.2: DE-0003.12 · Poison AI/ML Training for Evasion (detector tuning/staleness) · Notional risk: —
Secondary: Targeted Deception of Onboard Sensors (DE family)

IMPACT CONTEXT

Surface: Bus, sensors & FDIR ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 6: Add a slow-trend term alongside the EWMA: CUSUM or a slope check on µ itself catches

DETECTION EVIDENCE

• evidence/v124_ewma_ramp_evasion.txt (simulator) • evidence-hw/v124_ewma_ramp_evasion.txt (hardware, image H md5 bfc145c9…)

#49 [MEDIUM] Radio→I2C bridge: sensor mask rewrite + GPS blinding via GPIO write

Group: 6 · Bus, sensors & FDIR ■ PoC: v126_sensor_bus_injection.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

Two short paths turn the sensor subsystem into an attacker-facing interface.

TECHNICAL DETAILS

SPARTA v3.2: LM-0002 · Exploit Lack of Bus Segregation · Notional risk: 24|21|17
Secondary: EX-0014.03 Sensor Data; EX-0012.01 Registers

IMPACT CONTEXT

Surface: Bus, sensors & FDIR ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 6: Turn on `DEF_I2C_WHOAMI` (re-read `CHIP_ID` every poll, alarm on mismatch) — a few

DETECTION EVIDENCE

• evidence/v126_sensor_bus_injection.txt (simulator) • evidence-hw/v126_sensor_bus_injection.txt (hardware, image H md5 bfc145c9…)

#50 [MEDIUM] 64-sample RF fingerprint export (RSSI/SNR/freq-error) usable for LR detector

Group: 1 · Recon & leakage ■ PoC: v129_rf_fingerprint.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

The firmware keeps a 64-deep ring window of RF measurements (RSSI, SNR, frequency error) taken on every received telecommand and will export its aggregate statistics over a raw, unauthenticated command — and it will also *reset* t...

TECHNICAL DETAILS

SPARTA v3.2: REC-0005 · Eavesdropping · Notional risk: —
Secondary: DE-0003.04 RSSI; REC-0005.01

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Gate TC_STATS export behind GS mode/authentication (a handful of

DETECTION EVIDENCE

• evidence/v129_rf_fingerprint.txt (simulator) • evidence-hw/v129_rf_fingerprint.txt (hardware, image H md5 bfc145c9…)

#51 [MEDIUM] Unauthorized payload snap + VCC audit-counter freeze

Group: 5 · Ground segment & downlink ■ PoC: v131_payload_snap_audit.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

`PAYLOAD_SNAP` takes an instant "pseudo-image" — a 32-byte pack of live sensor readings and vehicle state — with the payload explicitly **not armed**, and stages it in the covert queue for later exfiltration over the legitimate do...

TECHNICAL DETAILS

SPARTA v3.2: DE-0003.01 · On-Board Values Obfuscation: Vehicle Command Counter (VCC) · Notional risk: —

Secondary: EXF-0003.02 Downlink Exfiltration (data capture)

IMPACT CONTEXT

Surface: Ground segment & downlink ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 5: Refuse `PAYLOAD_SNAP` unless the payload is armed **and** the request came

DETECTION EVIDENCE

• evidence/v131_payload_snap_audit.txt (simulator) • evidence-hw/v131_payload_snap_audit.txt (hardware, image H md5 bfc145c9…)

#52 [MEDIUM] Downlink frequency squat via BROADCAST_MSG operator-frequency field

Group: 5 · Ground segment & downlink ■ PoC: v132_freq_squat.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

`BROADCAST_MSG` carries a two-byte operator-frequency field in front of the echoed message, and the craft transmits the broadcast **on that frequency** while latching it as the "last used" downlink frequency.

TECHNICAL DETAILS

SPARTA v3.2: DE-0003.06 · On-Board Values Obfuscation: Telemetry Downlink Modes · Notional risk: —

Secondary: IMP-0008 State or Mode Manipulation (v4.0); IMP Denial (lost contact)

IMPACT CONTEXT

Surface: Ground segment & downlink ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 5: Ship `FREQ_LOCK` **on** by default (the defense exists and demonstrably

DETECTION EVIDENCE

• evidence/v132_freq_squat.txt (simulator) • evidence-hw/v132_freq_squat.txt (hardware, image H md5 bfc145c9…)

#53 [MEDIUM] Unauthenticated FLASH dump + banner TMs pin the open-source fork and version

Group: 1 · Recon & leakage ■ PoC: v137_build_metadata.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.50**	**MEDIUM**
RELEVANCE	**1.00**	**APPLIABLE**
PRIORITY	**0.50**	**MEDIUM**

Three ambient leaks identify the flight software exactly: `SEND_FW` returns the version triple over the raw radio; `FLASH` (APID `0x07`) dumps the whole 256-byte application image — unauthenticated — with its embedded build string...

TECHNICAL DETAILS

SPARTA v3.2: REC-0001.01 · Gather Spacecraft Design Information: Software Design (.02 Firmware) ·
Notional risk: —
Secondary: EXF-0003.02; REC-0002.01

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Gate `FLASH` dump and version detail behind GS mode; return an opaque,

DETECTION EVIDENCE

• evidence/v137_build_metadata.txt (simulator) • evidence-hw/v137_build_metadata.txt (hardware, image H md5 bfc145c9…)

07
Low Severity Findings (3)

#54 [LOW] GS_STATUS leaks ground-station coordinates to any poller

Group: 1 · Recon & leakage ■ PoC: v018_gs_status_station_leak.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.25**		**LOW**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.25**		**LOW**

The GS_STATUS telemetry frame publishes the ground station's own geography: latitude, longitude, and the protected access radius.

TECHNICAL DETAILS

SPARTA v3.2: REC-0003 · Gather Spacecraft Communications Information · Notional risk: —
Secondary: REC-0003.02 Commanding Details; EXF-0003.02

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Remove station coordinates from the downlink TM (the spacecraft needs them, the

DETECTION EVIDENCE

• evidence/v018_gs_status_station_leak.txt (simulator) • evidence-hw/v018_gs_status_station_leak.txt (hardware, image H md5 bfc145c9…)

#55 [LOW] Per-TC RSSI/SNR/APID oracle exported unauthenticated

Group: 1 · Recon & leakage ■ PoC: v103_tc_rssi_oracle.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.25**		**LOW**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.25**		**LOW**

Every telecommand the receiver accepts is sampled — RSSI, SNR, estimated frequency error — and the running statistics are handed back, unauthenticated, by a single query (`TC_STATS`, APID 0x20).

TECHNICAL DETAILS

SPARTA v3.2: REC-0005 · Eavesdropping (.01 Uplink Intercept Eavesdropping) · Notional risk: —
Secondary: DE-0003.04 Command Receivers Received Signal Strength

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Gate `TC_STATS` behind the GS session / SDLS MAC (CM0031 Authentication): the

DETECTION EVIDENCE

• evidence/v103_tc_rssi_oracle.txt (simulator) • evidence-hw/v103_tc_rssi_oracle.txt (hardware, image H md5 bfc145c9…)

#56 [LOW] TM cadence + beacon eclipse bit reveal operator pass plan and orbit phase

Group: 1 · Recon & leakage ■ PoC: v106_pass_cadence.py ■ Targets: simulator + FlatSat 1 ■ Status: VERIFIED

SEVERITY	**0.25**		**LOW**
RELEVANCE	**1.00**		**APPLIABLE**
PRIORITY	**0.25**		**LOW**

Nothing on the firmware side is "broken" here — that is the point.

TECHNICAL DETAILS

SPARTA v3.2: REC-0003.02 · Gather Spacecraft Communications Information: Commanding Details · Notional risk: —

Secondary: REC-0002.03 Operations

IMPACT CONTEXT

Surface: Recon & leakage ■ Interface: unauthenticated uplink (RF/USB)

REMEDIATION

docs/DEFENSE.md · group 1: Randomize inter-TM jitter (±20 %) and vary APIDs per pass state: cheap, breaks exact

DETECTION EVIDENCE

• evidence/v106_pass_cadence.txt (simulator) • evidence-hw/v106_pass_cadence.txt (hardware, image H md5 bfc145c9…)

08
Scope & Infrastructure

In-scope systems

System	Role in assessment
FlatSat 1 board (RP2040, 2× SX1262 LoRa, BME280, LIS2DH12, 4 MB flash)	Test target — real firmware, over USB bench transport and ISM-band LoRa
Bit-for-bit Python simulator (simulator/flatsat_sim.py)	Authoritative behavioural reference — same PoC, second target
Bench harness (poc/lib/fslab.py, FEED-window protocol 0x26/0x27)	Deterministic time control — what makes sim ≡ silicon

Out of scope

- Other hardware revisions, the SX1262 RF front-end as physical hardware, and any network not owned by the operator.
- Physical security (the board itself) and the upstream v1.0.3 release as distributed (assessed via its public source).

Constraints

The system is intentionally vulnerable; findings are not defects of a product but the designed behaviour of a laboratory. Hardware evidence was captured on firmware image H (UF2 335872 B, md5 bfc145c93039177b7393147978cdd432); three transcripts (v003, v015, v135) are annotated in hw_pass.txt as by-design impact evidence captured on earlier images.

Realism: the flaw classes are those documented in real smallsat flight software; the configuration is a pedagogical amplifier (docs/REALISM.md carries the three-tier mapping and the in-orbit surface analysis).

09 Technology Stack

Layer	Technology
Firmware	C++ (Arduino-Pico), PlatformIO, pico_tinyusb; cores 0/1; flash store; SpaceCAN bridge; mission model; FDIR
Radio	2× Semtech SX1262 (dedicated uplink / downlink), ISM bands; SPP framing; AES-ECB link wrap (lab state)
Sensors	BME280 (environment), LIS2DH12 (IMU), GPS NMEA path (virtual on bench)
Bench / USB	TinyUSB CDC; LAB_STATUS 0x26 / LAB_CTRL 0x27; FEED-window epoch clock (sub 6), 60.0× cold-boot scale
Simulator	Python 3.14 — byte-for-bit behavioural twin of the firmware (self-test: FIPS-197, SP800-38A/B)
PoC framework	56 PoCs on a shared driver (poc/lib/fslab.py), --sim / --usb, transcript capture

10
Security Posture

The lab is not defenceless — it has real controls, deliberately misconfigured. That is the pedagogical point: each control below exists in working form and fails for a specific, documented reason.

Link cryptography (AES-128 engine)

IMPLEMENTED — MISCONFIGURED

The engine works (SP800-38B CMAC verified in self-test) but the key is compiled into the image, ECB mode is the transport, and the whole layer can be switched OFF over the air (V0-02, V0-10, V0-11).

Ground-station range gate

IMPLEMENTED — SPOOFABLE

GS arming is range-gated (35 km) but the position input is the unauthenticated NMEA path — the gate defends the thing the attacker controls (V-36, V0-05).

GPS plausibility gate

IMPLEMENTED — MISCALIBRATED

Active defense exists (DEF_GPS_PLAUS) but its 500 km/s threshold is ~65× LEO ground-track plausibility (~7.6 km/s); a 9500 km hop spread over 60 s passes (V-36).

FDIR / anomaly detection

IMPLEMENTED — UNVALIDATED INPUTS

EWMA anomaly feed and FDIR tree run, but they consume the same unauthenticated bus they watch — the safety loop can be laundered (V-24, V-27).

Flash-resident state

PRESENT — UNSIGNED

FDICT, task queue and ARWC persist across reboots with CRC-16 only — a checksum is not a signature (V-18, V-19, V-20, V-38).

Watchdog

ABSENT

No watchdog: a hung or crashed worker stays down until a physical power cycle (V0-15); crash PoCs wedge the real board by design (v003, v015, v135).

Overall posture: **WEAK** — no boundary (B1–B5 in the threat model) has an intact integrity mechanism.

11
Remediation Roadmap

Immediate (0–7 days) — stop the blood

- Authenticate the control plane: privileged TCs (mission mode, thrusters, heaters) only inside an authenticated session with CMAC challenge-response and fresh nonces (fixes V-36 handshake, V-28, V0-06 in one move).
- Bounds-check every external input at the frame layer before any copy; reject unbounded SPP lengths (V0-03, V0-04–V-05, V-09, V-13).
- Flash-lock the code region (VTOR immutable) and remove TC-writable debug APIDs (V-14, V0-09, V-37).

Short-term (7–30 days) — make state honest

- Signed OTA (asymmetric signature before CRC); flash stores signed and size-bounded; ARWC monotonic (V-18, V-19, V-20, V-38).
- NMEA checksum at the parser + fix-vs-propagator cross-check; plausibility threshold at a physically sane bound (~10 km/s) (V0-05, V0-17, V-36).
- Per-APID rate limits and a watchdog with clean-restart semantics (V0-08, V0-13–V0-15, V-15).

Medium-term (30–90 days) — depth and assurance

- Bus integrity (per-MID CMAC) so FDIR cannot be laundered; sensor plausibility fed into the anomaly detector (V-17, V-24–V-27).
- Beacon/downlink budgets with fairness; detumble authority bound above any attacker torque (V0-14, V-33, V-34, V-35).
- Standing fuzz CI on the frame parser; TC journal ON by default; TEST APID window closed by default (V-16, V-23; the V0-03 lesson).

Per-finding detail: docs/DEFENSE.md (9 groups, each with the broken control, the countermeasure, and the standard to check against).

12
Methodology & Verification

Phases (adapted PTES)

- **Recon:** public source review of the upstream firmware (Pwnsat/FlatSat v1.0.3, 22 source files read in full) + the lab firmware.
- **Vulnerability analysis:** 56 candidates mapped to SPARTA v3.2 (Aerospace) (The Aerospace Corporation, 2026-03-11); technique IDs and notional-risk scores verified against sparta.aerospace.org.
- **Exploitation:** one executable PoC per finding on the shared driver poc/lib/fslab.py; 56/56 POC OK on the simulator and on FlatSat 1 over USB (112 transcripts committed to the repository).
- **Post-exploitation:** persistence (V-19/V-20), OTA (V-18), and impact (crash/wedge PoCs v003/v015/v135) executed on both targets.

Bench parity as a verification method

The simulator advances its workers only inside advance(); the firmware's bench epoch clock (LAB_CTRL 0x27 sub 6 FEED_START) advances only inside a window, at 60.0× cold-boot scale. The same PoC therefore exercises both targets at the same model instants — a fix is proven on silicon with the same script that proves it on the simulator. CI re-runs the self-test, the 56-PoC sweep, host crypto vectors and the catalog integrity gate on every push; the release workflow re-builds the firmware and publishes UF2 + md5 on every tag.

Severity convention

Severity labels are the repository writeups' own assessments, cross-checked against the SPARTA v3.2 notional-risk triples quoted per finding. No CVSS vectors are assigned: SPARTA is the applicable space framework, and inventing web-style CVSS scores would misrepresent the domain.

Tools

In-house PoC framework (fslab.py) + the simulator; PlatformIO (firmware build); no external scanners. Evidence: 112 committed transcripts, all ending POC OK.

13
Appendix — Finding Cross-Reference

ID	Finding	Sev	Group	SPARTA v3.2 (primary)	PoC
V0-01	Unauthenticated SEND_FW + APID surface enumeration (CPE fingerpr	Medium	1	REC-0001.01	v001_send_fw_cpe.py
V0-02	Hardcoded AES-128 ECB link key `PWNsatLabKey1234` in image	Critical	2	REC-0001.03	v002_hardcoded_ecb_key.py
V0-03	BROADCAST_MSG length underflow → worker crash (silent death)	High	4	EX-0009.01	v003_broadcast_underflow_crash.py
V0-04	SET_THRUSTER accepted from raw radio, no authentication	High	3	EX-0005.02	v004_set_thruster_noauth.py
V0-05	GPS NMEA accepted without checksum → position spoofing	High	3	EX-0014.04	v005_gps_no_checksum.py
V0-06	GS authentication = challenge XOR static key (offline-computable	High	2	EX-0003	v006_gs_auth_xor_static.py
V0-07	No anti-replay protection on telecommands	High	2	EX-0001.01	v007_no_replay_protection.py
V0-08	RESETC unauthenticated → one-TC reboot DoS, window loss	Medium	9	EX-0005.02	v008_resetc_unauth_dos.py
V0-09	FLASH_READ guarded only by a hardcoded magic tag	Medium	1	REC-0001.02	v009_flash_read_hardcoded_tag.py
V0-10	Crypto-bypass: AES engine can be switched OFF over the air	High	2	EX-0006	v010_cleartext_downgrade.py
V0-11	AES-ECB malleability: TC bit-flip without any integrity check	High	2	EX-0009.01	v011_ecb_bitflip.py
V0-12	USB debug mode bypasses link authentication	Medium	2	IA-0011	v012_usb_debug_bypass.py
V0-13	SpaceCAN bridge: junk storm drives nodes BUS-OFF (bus jam)	High	9	LM-0002	v013_spacecan_busoff.py
V0-14	Beacon-flood (SET_BEACON_RATE) freezes the mission loop	High	9	EX-0013	v014_beacon_flood.py
V0-15	No watchdog: hang/crash survives indefinitely until power cycle	High	9	EX-0009.01	v015_no_watchdog.py
V0-16	SPP unpack off-by-one: TM payload over-read (RAM byte leak)	Medium	4	EX-0009.01	v016_spp_offbyone.py

V0-17	GPS parser `strtok` column handling → forged sentences accepted	Medium	3	EX-0014.03	v017_gps_strtok_columns.py
V0-18	GS_STATUS leaks ground-station coordinates to any poller	Low	1	REC-0003	v018_gs_status_station_leak.py
V-01	SEND_FW unauthenticated inventory/version leak (CPE match to CVE	Medium	1	REC-0001.01	v101_send_fw_inventory.py
V-02	Over-talkative beacon discloses mode, crypto state, battery, ecl	Medium	1	REC-0003	v102_chatty_beacon.py
V-03	Per-TC RSSI/SNR/APID oracle exported unauthenticated	Low	1	REC-0005	v103_tc_rssi_oracle.py
V-04	Heartbleed-style RAM leak inside TM 'padding' (GS challenge disc	High	4	EX-0009.01	v104_leak_padding.py
V-05	Arbitrary MEM_READ: SA table + GS challenge walk out over raw ra	High	4	EX-0012.03	v105_mem_read.py
V-06	TM cadence + beacon eclipse bit reveal operator pass plan and or	Low	1	REC-0003.02	v106_pass_cadence.py
V-07	16-bit volatile anti-replay counter, W=5 window, wraps at 65536	Medium	2	EX-0001.01	v107_arc_replay.py
V-08	43 of 64 SDLS security associations default to Clear (auth-free)	High	2	EX-0006	v108_sdls_clear_sas.py
V-09	Unbounded SPI: OOB table read passes; SPI 9000 hangs the worker	High	4	EX-0009.01	v109_spi_oob.py
V-10	OTAR with 128 NULL master keys: attacker installs his own SA key	Critical	2	PER-0004	v110_otar_null_key.py
V-11	KEY_VERIFY key-confirmation oracle + CTR keystream recoverable f	High	2	REC-0001.03	v111_key_verify_oracle.py
V-12	Silent TC tampering: clear-header APID re-routing + ECB block sp	High	3	EX-0012.02	v112_tc_bitflip.py
V-13	SET_LOG_NAME unbounded copy overwrites protection-state guard va	High	4	EX-0009.01	v113_log_name_overflow.py
V-14	MEMCPY TC → write-what-where → VTOR redirect → RP2040 RCE	Critical	4	EX-0009.01	v114_memcpy_rce.py
V-15	Uplink flood (blocking ledBlink + error TMs) starves telemetry	High	9	EX-0013.02	v115_uplink_starvation.py
V-16	TEST APID window (0xF0–0xFF) opens in safe mode, no own auth	High	8	EX-0011	v116_priv_confusion.py
V-17	Forged software-bus MIDs (cFS SB analogue) consumed as truth	High	6	EX-0014.02	v117_sb_forged_mids.py

V-18	Unsigned OTA image push + slot activation (CRC-16 only)	Critical	8	EX-0010	v118_ota_unsigned.py
V-19	Flash-resident scheduled task queue replays after any reboot	High	7	PER-0002.02	v119_sched_persistence.py
V-20	FDIR contingency dictionary = flash-resident executable trojan	High	7	PER-0002.02	v120_fdict_contingency.py
V-21	Persistence cookie in RP2040 watchdog scratch registers (boot po	Medium	7	PER-0001	v121_watchdog_cookie.py
V-22	Forced safe mode = protection downgrade (crypto off, ARC 5→15, p	High	8	DE-0005	v122_forced_safe_downgrade.py
V-23	No TC journal by default; optional log capped at 128 entries	Medium	8	DE-0003.08	v123_tc_logging_absent.py
V-24	On-board EWMA anomaly detector evadable by slow ramp	Medium	6	DE-0003.12	v124_ewma_ramp_evasion.py
V-25	Full unauthenticated SpaceCAN bus over the radio bridge (jam/spo	High	6	LM-0002	v125_spacecan_full_bus.py
V-26	Radio→I2C bridge: sensor mask rewrite + GPS blinding via GPIO wr	Medium	6	LM-0002	v126_sensor_bus_injection.py
V-27	FDIR consumes forged MIDs → attacker-launders control of the saf	High	6	EX-0014.03	v127_fdir_consumes_forged_mids.py
V-28	GS challenge has no TRNG (millis ^ GPS) → predicted-challenge se	High	5	EX-0003	v128_gs_session_hijack.py
V-29	64-sample RF fingerprint export (RSSI/SNR/freq-error) usable for	Medium	1	REC-0005	v129_rf_fingerprint.py
V-30	Covert channel inside TM padding drains a FIFO over the legitima	High	5	EXF-0004	v130_stego_padding_channel.py
V-31	Unauthorized payload snap + VCC audit-counter freeze	Medium	5	DE-0003.01	v131_payload_snap_audit.py
V-32	Downlink frequency squat via BROADCAST_MSG operator-frequency fi	Medium	5	DE-0003.06	v132_freq_squat.py
V-33	ADCS momentum spam (30 valid thruster TCs) → TUMBLE safe + detum	High	9	EX-0012.08	v133_adcstumble_saturation.py
V-34	Heater/eclipse power drain → brownout reset wipes ARC, cookie, c	High	9	EX-0012.09	v134_brownout_drain.py
V-35	Beacon/broadcast downlink saturation (service_control analogue)	High	9	EX-0013.01	v135_beacon_broadcast_saturation.py
V-36	GPS spoof → range-lock dissolve → XOR auth → privileged control	High	3	EX-0014.04	v136_gps_spoof_chain.py

V-37	Unauthenticated FLASH dump + banner TMs pin the open-source fork	Medium	1	REC-0001.01	v137_build_metadata.py
V-38	Anti-rollback counter writable by TC → patch level unenforceable	High	7	EX-0009.03	v138_arwc_rollback.py

Evidence references

• evidence/ — 56 simulator transcripts (POC OK) • evidence-hw/ — 56 FlatSat 1 transcripts (POC OK, image H md5 bfc145c9…; v003/v015/v135 annotated in hw_pass.txt)
• docs/SPARTA_MAPPING.md — 56-row matrix pinned to SPARTA v3.2 (verified against sparta.aerospace.org)
• FINDINGS.json — machine-readable catalog, drift-checked by tests/host/check_catalog.py in CI

Glossary

• **SPP** — Space Packet Protocol frame (the wire unit of the bench transport) • **FEED window** — the bench's advance() time window (LAB_CTRL 0x27 sub 6)
• **FDICT** — flash-resident FDIR contingency dictionary • **ARWC** — anti-rollback write counter • **MID** — SpaceCAN message identifier
• **OTAR** — over-the-air rekey • **SDLS** — CCSDS 355.0-B-2 Space Data Link Security • **GS** — ground station